ฉบับผู้บริหาร · EXECUTIVE EDITION

ความมั่นคงปลอดภัยไซเบอร์ สำหรับเทคโนโลยีสุขภาพดิจิทัล

Cybersecurity in Digital Health Technology

สรุปสาระสำคัญจากหนังสือ 25 บท สำหรับผู้อำนวยการ ทีมบริหาร และ CIO ของโรงพยาบาลและหน่วยบริการสาธารณสุข อ่านจบใน 20 นาที พร้อมสิ่งที่ต้องตัดสินใจและคำถามที่ควรถามทีมงาน

1 ทำไมเรื่องนี้ถึงโต๊ะผู้บริหาร

2 หน้าที่ตามกฎหมายและ CTAM+

3 ผู้โจมตีเข้ามาอย่างไร

4 ลงทุนอะไรก่อน

5 แผน 12 เดือน

6 เมื่อเกิดเหตุต้องทำอะไร

7 รายงานและตัวชี้วัด

8 สิบคำถามถึงทีม IT

ฉบับเผยแพร่ 1.0 · ตุลาคม 2569

CC BY-NC-SA 4.0

สรุปในหน้าเดียว

1. ภัยไซเบอร์คือความปลอดภัยของผู้ป่วย ระบบ HIS หยุดหนึ่งชั่วโมงกระทบการรักษาทันที และข้อมูลสุขภาพที่รั่วไหลเรียกคืนไม่ได้

2. ผู้บริหารสูงสุดรับผิดชอบตามกฎหมาย ทั้ง พ.ร.บ.ไซเบอร์ (ภาคสาธารณสุขเป็น CII) PDPA (ปรับทางปกครองสูงสุด 5 ล้านบาทสำหรับข้อมูลอ่อนไหว) และนโยบายกระทรวง

3. ผู้โจมตีเร็วขึ้นมาก เข้าทางช่องโหว่ของอุปกรณ์ที่เปิดสู่อินเทอร์เน็ตเป็นอันดับ 1 และเคลื่อนที่ข้ามเครื่องได้ภายในราว 30 นาที

4. มาตรการที่คุ้มที่สุดราคาไม่แพง MFA, แพตช์ภายใน 72 ชั่วโมงสำหรับช่องโหว่ที่ถูกใช้โจมตีจริง, Backup แบบ Offline และการแจ้งเตือนถึงคนจริง

5. ไม่ต้องทำคนเดียว ใช้ระบบเฝ้าระวัง ข้อมูลภัย และทีมผู้เชี่ยวชาญร่วมกับจังหวัด เขตสุขภาพ และ Health CERT

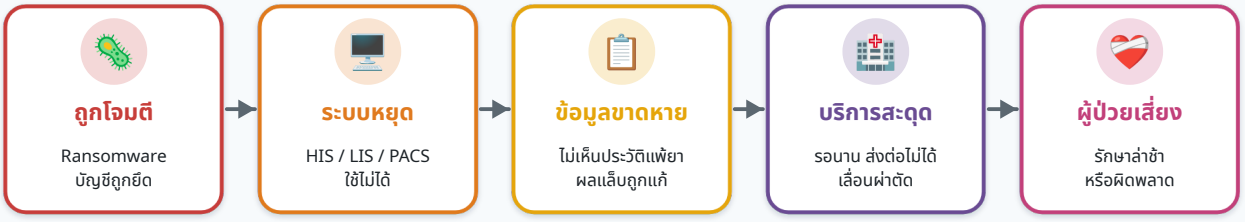
สิ่งที่ขอให้ผู้บริหารตัดสินใจ

#	การตัดสินใจ	ทำไม
1	แต่งตั้ง CISO และ DPO พร้อมทีมรับมือเหตุ และให้เวลางาน IT ทำงานความปลอดภัยอย่างน้อย 20%	กฎหมายกำหนด และเป็นข้อหาแรกที่ สคส. เคยลงโทษปรับ
2	อนุมัติแผน 12 เดือนตาม CTAM+ 17 ข้อ และติดตามรายไตรมาส	เกณฑ์ประเมินของกระทรวงและหลักฐานเมื่อเกิดเหตุ
3	บังคับ MFA ทุกการเข้าถึงจากภายนอก รวมบัญชี Vendor	ตัดช่องทางเข้าที่พบบ่อยที่สุดในเหตุ Ransomware
4	จัดงบ Backup แบบ Offline/Immutable และสั่งทดสอบกู้คืนทุกเดือน	ทางรอดเดียวเมื่อถูกเข้ารหัสข้อมูล
5	ซ้อมรับมือเหตุ (Tabletop) ร่วมกับทีมบริหารอย่างน้อยปีละครั้ง	ผู้บริหารคือผู้ประกาศ BCP และอนุมัติการแจ้งเหตุ

1 ทำไมเรื่องนี้ถึงโต๊ะผู้บริหาร

แหล่งข้อมูล	ตัวเลขสำคัญ
สกมช.	เหตุการณ์ภัยคุกคามไซเบอร์ในไทยปี 2567 รวม **2,135 ครั้ง** เพิ่มจาก 835 ครั้งในปี 2565
Verizon DBIR 2026	การใช้ช่องโหว่เป็นช่องทางเข้าอันดับ 1 (**31%**) และ Ransomware อยู่ใน **48%** ของเหตุข้อมูลรั่ว
Sophos Healthcare 2025	สาเหตุอันดับ 1 ของ Ransomware ในหน่วยบริการสุขภาพคือช่องโหว่ (**33%**) รองลงมาคืออีเมลอันตรายและรหัสผ่านรั่ว
CrowdStrike GTR 2026	เวลาเฉลี่ยตั้งแต่เข้าระบบได้จนเคลื่อนที่ข้ามเครื่องเหลือ **29 นาที**
HHS (สหรัฐฯ)	เหตุ Change Healthcare กระทบข้อมูลราว **190 ล้านคน**

ภัยไซเบอร์ส่งผลถึงผู้ป่วยได้อย่างไร



▲ ภัยไซเบอร์กระทบความปลอดภัยของผู้ป่วยโดยตรง

สิ่งที่สูญเสียเมื่อเกิดเหตุ	ตัวอย่าง
บริการผู้ป่วย	ต้องใช้กระดาษ งดรับส่งต่อ การรักษาล่าช้าหรือผิดพลาด
รายได้	เบิกจ่ายไม่ได้ ส่งข้อมูล 43 แฟ้มล่าช้า
ค่าใช้จ่าย	จ้างผู้เชี่ยวชาญ ซื้ออุปกรณ์ใหม่ ทำงานล่วงเวลา
กฎหมาย	โทษแพ่ง อาญา และปกครองตาม PDPA
ความเชื่อมั่น	ประชาชนไม่กล้าให้ข้อมูลจริงกับแพทย์

2 หน้าที่ตามกฎหมายและเกณฑ์ที่ต้องรู้

กฎหมาย/เกณฑ์	หน้าที่ที่ผู้บริหารต้องกำกับ	อ่านในเล่ม
พ.ร.บ.การรักษาความมั่นคงปลอดภัยไซเบอร์ พ.ศ. 2562	ภาคสาธารณสุขเป็น CII: ทำตามประมวลแนวทางปฏิบัติ ประเมินความเสี่ยงและตรวจสอบปีละครั้ง มีแผนรับมือและทีม CIRT รายงานเหตุโดยเร็ว	บทที่ 3
พ.ร.บ.คุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562	แต่งตั้ง DPO มีมาตรการรักษาความปลอดภัยที่เหมาะสม แจ้ง สคส. ภายใน 72 ชั่วโมงเมื่อข้อมูลรั่วและมีความเสี่ยง	บทที่ 4
พ.ร.บ.คอมพิวเตอร์	เก็บข้อมูลจราจรคอมพิวเตอร์ตามที่กฎหมายกำหนด	บทที่ 3
นโยบายและแนวปฏิบัติของกระทรวงสาธารณสุข	ผู้บริหารสูงสุดรับผิดชอบ มีนโยบายที่ลงนาม และตัวชี้วัดด้าน Cybersecurity	บทที่ 5
CTAM+ 17 ข้อ (ปี 2569)	เก็บหลักฐานครบ 17 เกณฑ์ ส่งประเมินตามรอบ	บทที่ 6
การแจ้งเหตุของกระทรวง	แจ้ง Health CERT ภายใน 24 ชั่วโมงเมื่อเกิดเหตุระดับสูงขึ้นไป	บทที่ 17

⚠️ สคส. เคยลงโทษปรับทางปกครองจาก 3 ข้อหา คือ ไม่แต่งตั้ง DPO ไม่มีมาตรการรักษาความปลอดภัยที่เหมาะสม และไม่แจ้งเหตุภายใน 72 ชั่วโมง ทั้งสามเรื่องโรงพยาบาลทำได้ทันที

CTAM+ 17 ข้อ: คำถามที่ผู้บริหารถามได้เลย

ข้อ	เกณฑ์	ถามทีม IT ว่า
1	Backup 3-2-1	กู้ HIS จากชุด Offline ได้ภายในกี่ชั่วโมง ทดสอบล่าสุดเมื่อไร
2	AV/EDR	เครื่องสำคัญมีกี่เครื่องที่ยังไม่มี
3	Access Control 12 เงื่อนไข	เปิดอะไรสู่อินเทอร์เน็ตบ้าง ปิดได้อีกไหม
4, 7	PAM และ MFA	บัญชีผู้ดูแลระบบและ VPN ทุกบัญชีมี MFA หรือยัง
5	BCP/DRP	ซ้อมครั้งล่าสุดเมื่อไร ใช้เวลากี่ชั่วโมงกลับมาให้บริการ
6, 13	Patch	ช่องโหว่วิกฤติค้างเกินกำหนดกี่รายการ
8	WAF	เว็บไซต์ทุกเว็บอยู่หลัง WAF หรือยัง
9, 10	Log 90 วันและ SIEM	ถ้าเกิดเหตุตอนตีสอง ใครเห็นการแจ้งเตือน
11, 16	VA และ Pentest	ผลรอบล่าสุดแก้ครบหรือยัง
12, 15	ทะเบียนทรัพย์สินและ License	มีเครื่องมือแพทย์และระบบอาคารในทะเบียนหรือยัง
14	Network Segmentation	ถ้าเครื่องผู้ใช้ติดมัลแวร์ จะลามถึงเซิร์ฟเวอร์ได้ไหม
17	นโยบายและอบรม	บุคลากรผ่านการอบรมปีนี้กี่เปอร์เซ็นต์

3 ผู้โจมตีเข้ามาอย่างไร และสิบจุดตัดวงจร



▲ ห่วงโซ่การโจมตีโรงพยาบาลและจุดที่ตัดได้

ลำดับ	มาตรการ	ตัดวงจรที่ขั้นไหน
1	MFA ทุกบัญชีที่เข้าจากภายนอกและบัญชีผู้ดูแลระบบ	ช่องทางเข้า, ยกระดับสิทธิ์
2	แพตช์อุปกรณ์ที่เปิดสู่อินเทอร์เน็ตภายใน 72 ชั่วโมงเมื่ออยู่ใน CISA KEV หรือมีคำเตือน	ช่องทางเข้า
3	ไม่มี RDP ฐานข้อมูล หรือ DICOM เปิดตรงสู่อินเทอร์เน็ต	ช่องทางเข้า
4	รหัส Local Admin ไม่ซ้ำกันทุกเครื่อง (Windows LAPS)	เคลื่อนที่ข้ามเครื่อง
5	EDR หรือการตรวจจับพฤติกรรมบนเซิร์ฟเวอร์สำคัญ	ทุกขั้น
6	แบ่งเครือข่าย จำกัด RDP/SMB ระหว่างเครื่องผู้ใช้	เคลื่อนที่ข้ามเครื่อง
7	Backup แบบ Offline/Immutable ทดสอบกู้คืนทุกเดือน	ผลกระทบ
8	ควบคุมทราฟฟิกขาออก แจ้งเตือนเมื่อผิดปกติ	ขโมยข้อมูล
9	แจ้งเตือนเหตุสำคัญถึงคนจริงภายในไม่กี่นาที	ตรวจจับ
10	Help Desk ยืนยันตัวตนก่อนรีเซ็ตรหัสผ่านหรือ MFA	ช่องทางเข้า (หลอกทางโทรศัพท์)

4 ลงทุนอะไรก่อน

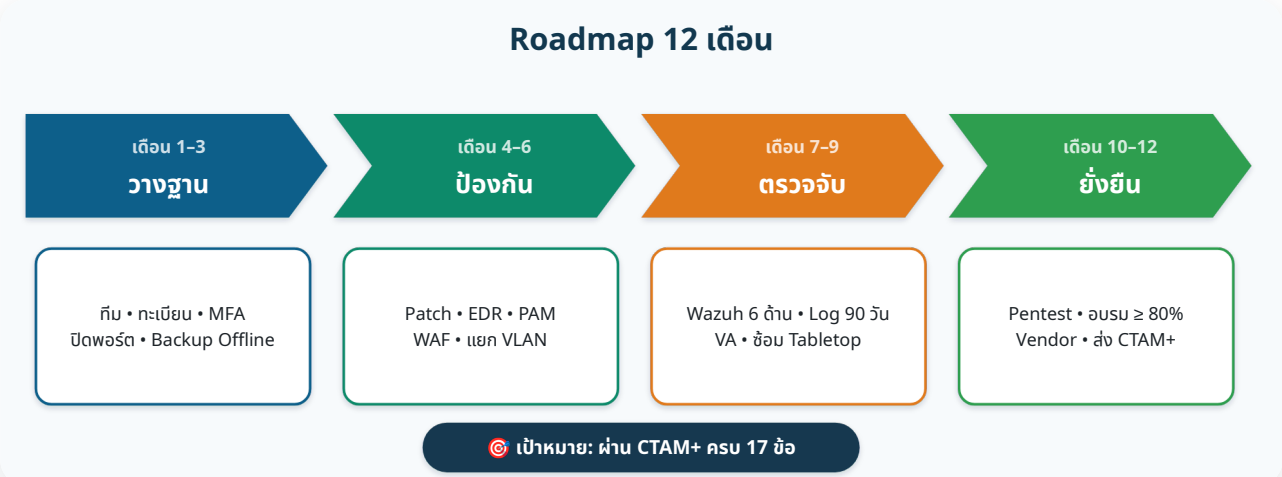
ช่วงเวลา	รพ.สต./ศสม.	รพช.	รพท./รพศ.	ระดับจังหวัด/เขต
ทำทันที (งบน้อย)	MFA อีเมล/บัญชีออนไลน์, Protective DNS, Backup Offline, อัปเดตอัตโนมัติ	+ Windows LAPS, Sysmon + Wazuh Agent, บัญชีล่อ, ZTNA สำหรับ Vendor	+ Firewall ระหว่างโซน, OpenCanary ทุก VLAN, Threat Hunting รายสัปดาห์	Wazuh กลาง, NCSA Blacklist Feed, สคริปต์ KEV, กลุ่มประสาน TLP
ภายใน 1 ปี	เครื่องที่รองรับ Windows รุ่นปัจจุบัน, รับ Feed จากจังหวัด	EDR บนเซิร์ฟเวอร์, FIDO2 สำหรับผู้ดูแลระบบ, SOAR เบื้องต้น	EDR ทุกเครื่องสำคัญ, NDR ที่ Core Switch, SSO	เชื่อม TCTI/MISP, จัดซื้อ EDR ร่วม, ทีมตอบสนองเร่งด่วน
ภายใน 2–3 ปี	เชื่อมผ่าน SASE/ZTNA ของจังหวัด	ตรวจสภาพเครื่องก่อนเข้า HIS	Microsegmentation, MFA ต้านฟิชชิง, Crypto Inventory	MDR/SOC 24 ชม. ระดับเขต, แผน PQC ร่วม

ทางเลือกต้นทุนต่ำ

รายการ	ทางเลือก
MFA	TOTP เช่น Google Authenticator หรือ FreeOTP
SIEM	Wazuh (โอเพนซอร์ส)
WAF	Nginx + ModSecurity + OWASP CRS หรือ Cloudflare แผนฟรี
Backup	Proxmox Backup Server + ฮาร์ดดิสก์สำรองแบบถอดได้
VA / Pentest	Greenbone/Nuclei และขอรับบริการจาก สกมช.
อบรม	สื่อฟรีจาก สกมช. สคส. และ TDGA + GoPhish

💡 ค่าใช้จ่ายที่หลีกเลี่ยงไม่ได้คือ **เวลาของคน** ให้เวลางาน IT ทำงานความปลอดภัยอย่างน้อย 20% และใช้บริการกลางของจังหวัด/เขตแทนการซื้อทุกอย่างเอง

5 แผน 12 เดือน



▲ Roadmap 12 เดือน

ช่วง	เป้าหมาย	งานหลัก
เดือน 1–3 วางฐาน	รู้ว่ามีอะไร ปิดรูใหญ่	แต่งตั้ง CISO/DPO/ทีม IR, ทะเบียนทรัพย์สิน, MFA ที่ VPN, ปิดพอร์ตที่ไม่จำเป็น, Backup Offline + ทดสอบกู้คืน
เดือน 4–6 ป้องกัน	ผ่าน CTAM+ ข้อ 1–8	Patch ตามกำหนด, EDR/AV ครบ, PAM, WAF, แยก VLAN อุปกรณ์การแพทย์, Hardening HIS DB
เดือน 7–9 ตรวจจับ	เห็นเหตุภายในชั่วโมง	Wazuh + กฎ 6 ด้าน, Log 90 วัน, VA รอบแรก, ซ้อม Tabletop
เดือน 10–12 ยั่งยืน	ผ่าน 17 เกณฑ์และทำซ้ำได้	Pentest, อบรม ≥ 80% + Phishing จำลอง, ทบทวนสัญญา Vendor, รายงานผู้บริหาร

6 เมื่อเกิดเหตุ: ผู้บริหารต้องทำอะไร

เวลา	ทีมเทคนิค	ผู้บริหาร
นาทีแรก	ดึงสายแลน/ปิด Wi-Fi เครื่องที่ติด ตัดการเชื่อมต่อ VPN ชั่วคราว ไม่ปิดเครื่องทันที	รับรายงาน เรียกทีมบริหารวิกฤติ
ชั่วโมงแรก	ตัด Backup/NAS ออกจากเครือข่าย ตรวจว่าชุด Offline สมบูรณ์	**ประกาศ BCP Code** ให้หน่วยบริการใช้ Downtime Procedure
ภายใน 24 ชม.	ระบุขอบเขตและช่องทางเข้า ส่ง SITREP ทุก 4–6 ชั่วโมง	อนุมัติการแจ้ง **Health CERT** สื่อสารบุคลากรผ่านช่องทางนอกระบบที่ถูกเจาะ
ภายใน 72 ชม.	กำจัดช่องทางเข้า เปลี่ยนรหัสผู้ดูแลทุกบัญชี	DPO ประเมินและ **แจ้ง สคส.** ถ้าเข้าเกณฑ์ เตรียมข้อความสื่อสารประชาชน
กู้คืน	ติดตั้งใหม่ กู้จาก Backup ที่สะอาด เรียงตามความสำคัญ	ตัดสินใจลำดับระบบที่กลับมาก่อน
หลังเหตุ	เฝ้าระวังเข้มข้นอย่างน้อย 30 วัน	สั่งถอดบทเรียน (AAR) ภายใน 2 สัปดาห์ และติดตามแผนปรับปรุง

⚠️ **ห้าม** ติดต่อหรือต่อรองกับผู้โจมตีเอง ห้ามเสียบ USB Backup เข้าเครื่องที่ติด และห้ามกู้คืนก่อนปิดช่องทางที่ผู้โจมตีใช้เข้า

ช่องทางแจ้งเหตุทางการ

หน่วยงาน	ช่องทาง	เมื่อใด
Health CERT	`health-cirt.moph.go.th`, `health-cirt@moph.go.th`, LINE `@health-cirt`	ภายใน 24 ชั่วโมง
สคส. (PDPC)	`pdpc.or.th`	ภายใน 72 ชั่วโมง เมื่อข้อมูลส่วนบุคคลรั่วไหลและมีความเสี่ยง
สกมช. / ThaiCERT	`ncsa.or.th`, `thaicert.or.th`	ผ่านกระทรวง หรือเมื่อต้องการความช่วยเหลือทางเทคนิค
ตำรวจไซเบอร์	`thaipoliceonline.go.th`	เมื่อจะดำเนินคดี

7 รายงานและตัวชี้วัดที่ควรขอดู

รายงานผู้บริหาร 1 หน้าต่อไตรมาส (ตัวอย่าง)

หัวข้อ	สถานะ	แนวโน้ม	ต้องการการตัดสินใจ
ระดับ CTAM+	14/17 เกณฑ์	▲ จาก 11	อนุมัติงบ WAF/MFA
ช่องโหว่วิกฤติค้างเกินกำหนด	2	▼	ยอมรับความเสี่ยงอุปกรณ์ Lab รุ่นเก่า?
Backup ทดสอบกู้คืนสำเร็จ	3/3 ระบบหลัก	—	—
เหตุการณ์ P1/P2	0 / 1 (บัญชีถูกยึด แก้แล้ว)	—	—
บุคลากรผ่านอบรม	76%	▲	ให้หัวหน้างานติดตาม

ตัวชี้วัดรายเดือน

ตัวชี้วัด	เป้าหมายที่แนะนำ
ความคืบหน้า CTAM+	17/17 ภายในรอบประเมิน
ยืนยันคำเตือนระดับวิกฤติภายใน 24 ชม.	≥ 95%
เวลาแก้ช่องโหว่วิกฤติ (ค่ามัธยฐาน)	≤ 3 วัน
เซิร์ฟเวอร์และเครื่องสำคัญที่ส่ง Log	≥ 95%
ทดสอบกู้คืนข้อมูล	ทุกเดือน
บุคลากรผ่านการอบรม (สะสมในปีงบประมาณ)	≥ 80%

💡 แผ่นงาน “สรุป” ในไฟล์ Excel ของ Toolkit คำนวณตัวชี้วัดเหล่านี้จากทะเบียนต่าง ๆ ให้อัตโนมัติ

8 สิบคำถามที่ผู้บริหารควรถามทีม IT

1. ถ้า HIS ถูกเข้ารหัสคืนนี้ พรุ่งนี้เช้าเราให้บริการอย่างไร และกู้คืนได้ภายในกี่ชั่วโมง
2. Backup ชุดไหนที่ผู้โจมตีลบหรือเข้ารหัสไม่ได้ ทดสอบกู้คืนล่าสุดเมื่อไร
3. มีระบบอะไรบ้างที่เปิดให้เข้าจากอินเทอร์เน็ต และทุกระบบมี MFA หรือยัง
4. ช่องโหว่ที่ถูกใช้โจมตีจริงค้างอยู่กี่รายการ เกินกำหนดกี่รายการ
5. ถ้ามีการแจ้งเตือนตอนตีสอง ใครเห็น และใครมีอำนาจตัดเครือข่าย
6. ผู้รับเหมาคนไหนเข้าระบบเราได้บ้าง เข้าทางไหน และมีบันทึกหรือไม่
7. เครื่องมือแพทย์และระบบอาคารที่ใช้ระบบปฏิบัติการเก่า ถูกแยกเครือข่ายแล้วหรือยัง
8. ถ้าข้อมูลผู้ป่วยรั่ว เรารู้ได้อย่างไร และใครแจ้ง สคส. ภายใน 72 ชั่วโมง
9. เราซ้อมรับมือเหตุครั้งล่าสุดเมื่อไร ได้บทเรียนอะไร แก้ไปแล้วกี่ข้อ
10. ทีมต้องการอะไรจากผู้บริหารมากที่สุดในไตรมาสนี้

ประเมินตนเองด้วยระดับวุฒิภาวะ



▲ ระดับวุฒิภาวะ 0–4 ใช้กับ 10 ด้านในภาคผนวก ฉ ของหนังสือ

ชุดเครื่องมือที่มากับหนังสือ

ไฟล์	ใช้ทำอะไร
Cyber-Health-Toolkit.xlsx	CTAM+ 17 ข้อ, Maturity, Risk Register, ทะเบียนทรัพย์สิน, ติดตามช่องโหว่/KEV, ทดสอบกู้คืน, ทะเบียนเหตุ, การอบรม และหน้าสรุป
แม่แบบ Word 6 ไฟล์	นโยบาย, แบบรายงานเหตุ, SITREP, AAR, คำเตือนภัยและแบบรายงานกลับ, แบบทดสอบก่อน/หลังอบรม
โปสเตอร์ 2 แผ่น	กฎทอง 10 ข้อสำหรับบุคลากร และขั้นตอนเมื่อสงสัยว่าถูกโจมตี